Rapport TP 4.3 SUPERVISION DE SECURITE AVEC UN SIEM (Wazuh)

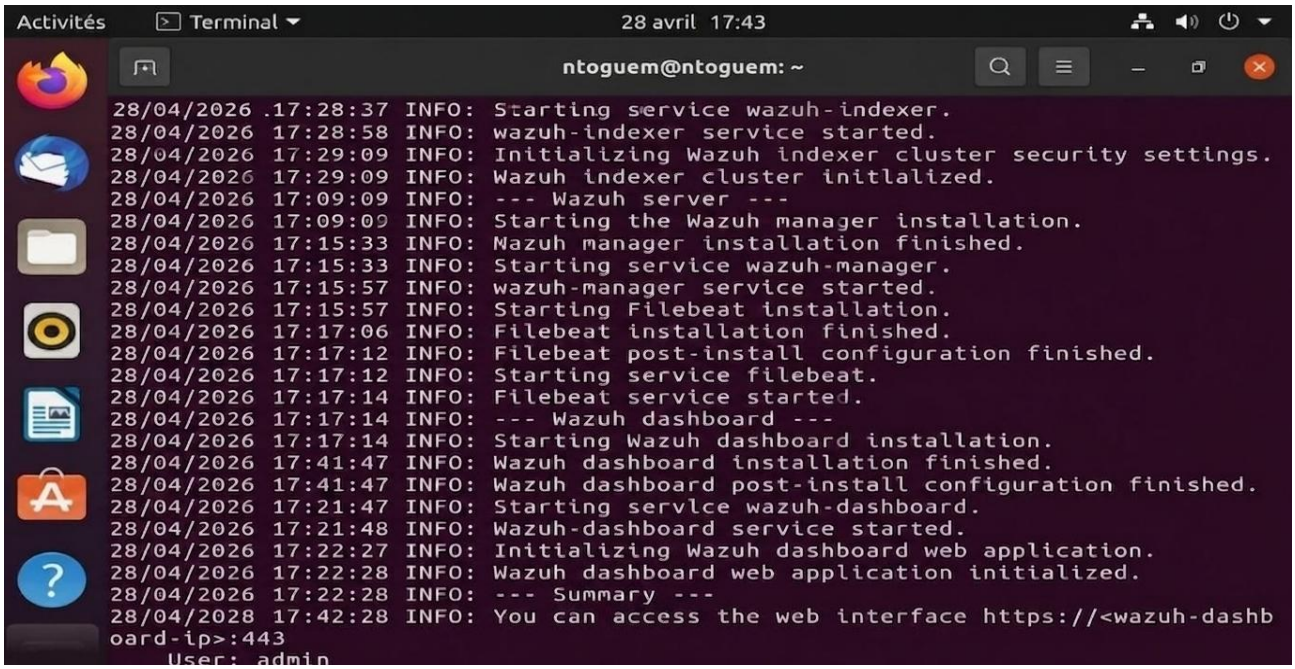
1. Introduction et Objectifs

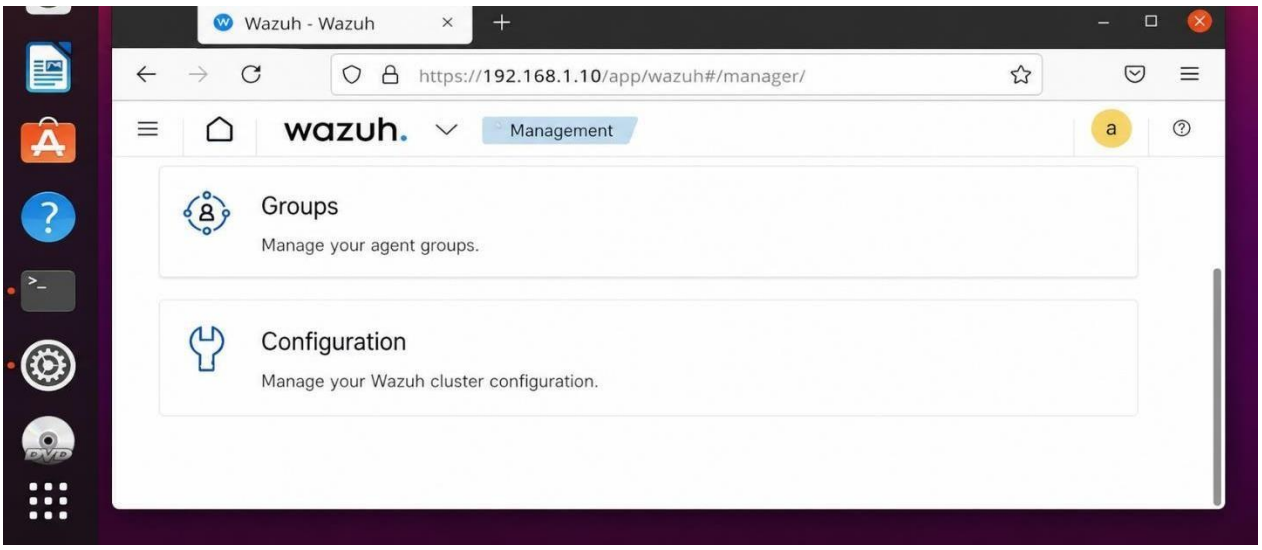
Ce rapport documente la mise en place d'une solution de gestion des informations et des événements de sécurité (SIEM) au sein d'un laboratoire de test. L'objectif principal était de centraliser la surveillance des systèmes Linux et Windows, ainsi que les alertes réseau issues de Suricata, afin d'obtenir une visibilité globale sur les menaces potentielles.

2. Installation et Configuration de l'infrastructure

2.1 Déploiement du Serveur Wazuh

Le serveur Wazuh a été installé sur une machine dédiée Ubuntu 22.04. L'utilisation du script d'installation automatisé a permis de déployer simultanément le serveur Wazuh, l'indexeur Elasticsearch pour le stockage des logs, et l'interface web Kibana pour la visualisation.



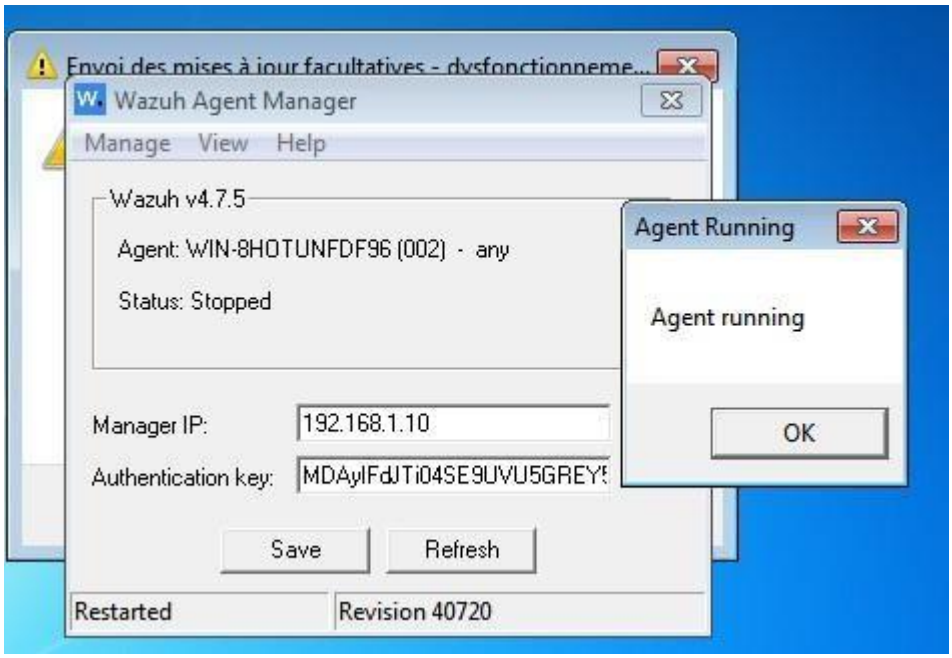


2.2 Déploiement des Agents de Surveillance

Pour permettre la remontée d'informations, des agents Wazuh ont été installés sur les machines cibles :

- **Sur Ubuntu :** Installation via le paquet `.deb` et configuration du fichier `ossec.conf` pour pointer vers l'IP du serveur.

- **Sur Windows :** Installation via l'exécutable officiel et renseignement des paramètres de connexion au serveur.



3. Simulations d'attaques et Détection

3.1 Création d'un utilisateur suspect (Linux)

Une première simulation a consisté à créer un utilisateur local nommé `testintrusion` sur la machine Ubuntu.

- **Résultat :** Wazuh a immédiatement détecté l'événement et a généré une alerte liée à la gestion des comptes utilisateurs.

3.2 Modification de fichiers critiques (FIM)

La surveillance de l'intégrité des fichiers (FIM) a été testée en modifiant le fichier `/etc/passwd`.

- **Résultat :** Une alerte de haute priorité a été déclenchée, confirmant que toute modification de fichiers système sensibles est tracée en temps réel.

3.3 Attaque réseau et corrélation (Suricata)

Enfin, une attaque par balayage de ports (Nmap) a été lancée depuis la machine Kali.

• **Résultat :** Le SIEM a corrélé les alertes provenant de l'IDS réseau Suricata avec les logs système.

Cela permet de répondre aux trois questions clés de l'analyste : ○ **Qui attaque ?** La machine Kali (IP source). ○ **Quelle machine est ciblée ?** Le serveur ou le poste client visé. ○ **Quelles actions sont réalisées ?** Tentative de scan et reconnaissance réseau.

4. Analyse Théorique : Le rôle du SIEM

Le SIEM (Security Information and Event Management) agit comme le cerveau du SOC. Son rôle se décline en trois étapes fondamentales :

1. **Collecte des logs :** Il récupère les données provenant de sources hétérogènes (serveurs, terminaux, pare-feu, IDS).
2. **Analyse et Corrélation :** Il lie des événements isolés entre eux. Par exemple, un scan réseau (Suricata) suivi d'une tentative de connexion réussie (Agent Wazuh) devient une alerte critique grâce à la corrélation.
3. **Alerte et Visualisation :** Il transforme des milliers de lignes de logs bruts en un tableau de bord lisible, permettant à l'analyste de réagir rapidement en cas d'incident.

5. Propositions d'améliorations

Pour rapprocher ce laboratoire d'un environnement de production en entreprise, je suggère les améliorations suivantes :

- **Intégration plus poussée de Suricata :** Affiner les règles de Suricata pour réduire les faux positifs et les importer directement dans des tableaux de bord personnalisés sous Wazuh.
- **Automatisation de la réponse (Active Response) :** Configurer Wazuh pour qu'il bloque automatiquement l'IP d'un attaquant (via le pare-feu local) après un certain nombre de tentatives de connexion échouées.
- **Extension du périmètre :** Ajouter la surveillance de serveurs de bases de données et d'équipements réseau (switchs/routeurs) via le protocole Syslog.
- **Création de rapports de conformité :** Mettre en place des rapports hebdomadaires automatiques basés sur des standards comme le RGPD ou le NIST.

Conclusion

Ce TP a permis de démontrer l'efficacité de Wazuh en tant que plateforme de supervision. La capacité à centraliser les événements réseau et système offre une vision panoramique indispensable à tout analyste SOC pour assurer la défense d'un système d'information.